

Yieldy EVM Contracts Audit Summary

Prepared by Cyfrin

Version 2.0

Head of Security Research

Dacian (Proprietary AI)

Lead Auditors

Flint

AliKalout

November 12, 2026

Contents

1 About Cyfrin **2**

2 About This Document **2**

3 Disclaimer **2**

4 Copyright and License **2**

5 Audit Overview **3**

6 Audit Scope **4**

7 Protocol Summary **4**

7.1 Components 4

7.2 Act Lifecycle 5

8 Attestation **5**

1 About Cyfrin

Cyfrin is a Web3 security company dedicated to bringing industry-leading protection and education to our partners and their projects. Our goal is to create a safe, reliable, and transparent environment for everyone in Web3 and DeFi. Learn more about us at cyfrin.io.

2 About This Document

This document is a public summary of the security audit Cyfrin performed for Yieldy on Yieldy EVM Contracts. It records the repositories and commits reviewed, the timeline, auditors, in-scope files, and the number and final status of findings by severity. It closes with Cyfrin's attestation of the review's scope and final remediation status.

Technical details of individual findings are omitted from this public summary to limit disclosure of security-sensitive information. The complete audit report was delivered privately to Yieldy, who retain it as the full record of the engagement. Recipients of the full report can use the SHA-256 hash in this summary's attestation to confirm that their copy matches the referenced report.

3 Disclaimer

The Cyfrin team makes every effort to find as many vulnerabilities in the code as possible in the given time but holds no responsibility for the findings in this document. A security audit by the team does not endorse the underlying business or product. The audit was time-boxed and the review of the code was solely on the security aspects of the in-scope code being audited. Unless the scope explicitly notes otherwise, the review is limited to the application layer and does not extend to the correctness of API/SDK/execution environment implementations, compilers, standard and third-party libraries, underlying operating systems and hardware.

4 Copyright and License

© 2026 Cyfrin Inc. All rights reserved. Material from Yieldy or third parties remains the property of its owners.

This summary may be shared only in complete and unmodified form, so that any copy can be checked against the hash in its attestation. Short quotations with attribution to Cyfrin are permitted, provided they do not misrepresent this summary's scope or results. Except as permitted by applicable law, no part of this summary may otherwise be copied, modified, adapted, sold or sublicensed, or used to create derivative works, without Cyfrin's prior written permission.

Cyfrin and the Cyfrin logo are trademarks of Cyfrin Inc. and may not be used to suggest that Cyfrin has reviewed or endorses anything outside this summary's scope, or to misrepresent its results.

5 Audit Overview

Over the course of 7 days, the Cyfrin team conducted an audit on the Yieldy EVM Contracts code provided by Yieldy. The findings consist of 1 Medium & 22 Low severity issues with the remainder being informational and gas optimizations.

Summary

Project Name	Yieldy EVM Contracts
Repository	yld-evm
Commit	bbcb18c9142a...
Fix Commit	7f57439b6206...
Audit Timeline	Oct 19th - Oct 27th, 2026
Methods	Manual Review, Proprietary AI

Issues Found

Severity	Found	Resolved	Acknowledged
Critical Risk	0	0	0
High Risk	0	0	0
Medium Risk	1	1	0
Low Risk	22	15	7
Informational	16	11	5
Gas Optimizations	5	4	1
Total	44	31	13

How to read the statuses

Resolved means Cyfrin verified the remediation documented in the full report with a Cyfrin verification note. Acknowledged means Yieldy chose to retain the reported behavior or accept the residual risk; this does not constitute resolution or endorsement by Cyfrin. Finding-specific explanations and verification notes are recorded in the full report.

Risk Classification

	Impact: High	**Impact: Medium**	**Impact: Low**
Likelihood: High	Critical	High	Medium
Likelihood: Medium	High	Medium	Low
Likelihood: Low	Medium	Low	Low

6 Audit Scope

The audit scope was limited to the following files:

```
src/StrategyManager.sol
src/Registry.sol
src/Logic.sol
src/Executor.sol
src/families/AaveV3Family.sol
src/families/CometFamily.sol
src/families/ERC4626Family.sol

// added in commit 90bf1a4 after audit start
src/YieldyCallPolicy.sol

// added during mitigation, reviewed at fix commit 12bf177
src/families/Venues.sol
src/families/VaultV2Family.sol
src/LogicConstants.sol
src/KernelAccount.sol

// constants imported by in-scope files
src/families/Price.sol
src/Rounding.sol
```

The following were out of scope: Yieldy's backend, monitoring and frontend; the ZeroDev Kernel account, validators and factory, and the token paymaster; the third-party venues Yieldy integrates (Aave, SparkLend, Compound III, Morpho, Spark, Fluid and Yearn) and their oracles; OpenZeppelin and other library code; and the deployment and configuration scripts, except where a finding covers them.

7 Protocol Summary

Yieldy is a yield automation protocol for stablecoins, launching on Ethereum. Each user holds their funds in their own ZeroDev Kernel ERC-4337 smart account, and Yieldy puts that money to work in established third-party venues: Aave v3 and SparkLend, Compound III, and ERC-4626 vaults such as Morpho. Funds are only ever in the user's account or in the venue it deposited into; Yieldy's contracts route each deposit, withdrawal and fee collection through a single front door but hold nothing between calls. The user keeps full control through the account's root key, while Yieldy's backend manages the strategies through a session key restricted to the calls those strategies need.

Each smart account holds one of three plans, set once and never changed. Protect pays a yearly fee on value; Save and Invest pay a share of net gain above a line that deposits raise and withdrawals lower. Fees are capped in code and are never taken by a deposit or withdrawal, only through `StrategyManager::collectFee` to the treasury the `Registry` names.

7.1 Components

Component	Role
`StrategyManager`	The front door: `act` runs one catalogued route per call, `collectFee` pays what is owed to the treasury
`Executor`	Pass-through that makes the venue call and forwards the route's tokens, holding nothing between calls
`Registry`	Routes, each receipt's asset, the fee treasury and the roles; changed only by the timelock

Component	Role
`Logic` / `Venues` / `VaultV2Family`	Entry gate, venue call plans, pricing and each position's fee record; `Logic` is upgradeable by the timelock until frozen
`AaveV3Family` / `CometFamily` / `ERC4626Family`	Per-venue calls and unit pricing for Aave v3 and SparkLend, Compound III and ERC-4626 vaults
`YieldyCallPolicy`	Limits the session key to the calls Yieldy's strategies need, in operations paid for by a pinned paymaster
`KernelAccount` / `LogicConstants` / `Price` / `Rounding`	Shared constants and the derivation of the owner's Kernel account addresses

7.2 Act Lifecycle

1. **Entry.** The account calls `StrategyManager::act` with a catalogued route. `Logic::gate` checks the route against the account's plan and scope, the `Executor` pulls the tokens and runs the venue calls `Logic::plan` builds, and the receipt goes back to the account. `Logic` records the position.
2. **Withdrawal or move.** An exit skips the gate, so only a timelocked removal of its route can block it. The `Executor` redeems at the venue and forwards the output to the account, or on a move the receipts to the owner's other account. `Logic` updates the position; no fee is taken.
3. **Collection.** `StrategyManager::collectFee` redeems receipts to pay what `Logic` records as owed, sends the fee only to the `Registry`'s treasury and returns the rest to the account.

8 Attestation

Cyfrin attests that it performed a security review of the Yieldy EVM Contracts code provided by Yieldy.

The repositories, commits, review period and findings with their final status are in the Summary and Issues Found tables in Section 5, and the in-scope files in Section 6. This attestation is limited to the documented scope, audited commits and mitigations specifically reviewed by Cyfrin.

Cyfrin publishes this document and its SHA-256 hash at https://github.com/Cyfrin/cyfrin-audit-reports. To check a copy on macOS or Linux, run the following in the folder that contains it; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name. Before running it, check that the URL is Cyfrin's repository.

```
U=https://github.com/Cyfrin/cyfrin-audit-reports/raw/main/reports/sha256
N=2026-11-12-cyfrin-yieldy-evm-contracts-v2.0.pdf
F=$N
H=$(curl -fsSL $U/$N.sha256 | cut -d' ' -f1)
echo "$H *$F" | shasum -a 256 -c
```

Cyfrin's full audit report with all findings provided to Yieldy has the SHA-256 hash and file name below. To check a copy of it, first check this document as above, then run the following in the folder that contains the full report; it prints `OK` when the copy matches. If the copy was renamed, set F to its file name.

```
H=efff30105f61d439de5665d9d09faa40921fda2844902a6629b241b7ab863bdb
F=2026-11-12-cyfrin-yieldy-evm-contracts-v2.0-full.pdf
echo "$H *$F" | shasum -a 256 -c
```

On Linux, `sha256sum -c` can be used in place of `shasum -a 256 -c`. On Windows, run `Get-FileHash <file> -Algorithm SHA256` in PowerShell and compare the result with the hash.